

DB 암호화 정책서

수탁사	(주)해랑금융
위탁사	하랑항공
문서 번호	HARANG-SEC-2025-062
작성일	2025년 11월
작성자	(서명)
승인자	(서명)
문서 버전	v1.0

본 문서는 PCI-DSS Req.3, 전자금융거래법 제22조, 개인정보보호법 시행령 제30조에 따른 금융 수탁사 전용 암호화
증적자료입니다. 외부 공개 금지.

DB 암호화 정책서

1. 목적 및 적용 범위

목적	개인정보 및 금융거래 데이터를 안전한 암호화 알고리즘으로 보호하여 개인정보보호법·전자금융거래법·PCI-DSS 요건을 충족함
적용 범위	결제 DB / API Gateway / SFTP 서버 / 내부 NAS에 저장되는 모든 개인정보 및 금융거래 데이터
적용 법령	개인정보보호법 제23·24·29조, 안전성 확보조치 기준 제7조, 전자금융거래법 제22조, PCI-DSS Req.3-4
문서 소유자	정보보호팀장 (CPO 승인)
검토 주기	연 1회 이상 (관련 법령 개정 시 즉시 검토)

2. 암호화 대상 및 적용 알고리즘

구분	데이터 항목	암호화 방식	알고리즘	키 길이	적용 시스템
고유식별정보	카드번호	토큰화(PCI-DSS)	PCI-DSS Tokenization	N/A	결제 DB
고유식별정보	계좌번호	대칭키 암호화	AES-256-GCM	256bit	결제 DB
개인정보	성명·연락처	대칭키 암호화	AES-256-CBC	256bit	결제 DB / API GW
인증정보	사용자 비밀번호	일방향 해시	bcrypt (cost 12)	N/A	전 시스템
전송 데이터	API 연동 구간	전송 암호화	TLS 1.3 / mTLS	256bit	API Gateway
전송 데이터	SFTP 파일 전송	파일 암호화	PGP + TLS	4096bit	SFTP 서버

※ 취약 알고리즘(MD5, SHA-1, DES, 3DES, RC4)은 전면 사용 금지. 분기 1회 적용 현황 점검 필수.

3. 암호화 적용 현황 확인 (점검 시 기입)

시스템	확인 항목	설정 값	확인 방법	확인자	확인일
결제 DB	카드번호 토큰화 적용		DB 스키마 조회		
결제 DB	계좌번호 AES-256 암호화		암호화 설정 캡처		
결제 DB	취약 알고리즘 미사용		코드 리뷰		
API Gateway	TLS 1.3 적용		SSL Labs 스캔		
SFTP 서버	PGP 암호화 적용		전송 테스트		
전 시스템	bcrypt 비밀번호 해시		코드 리뷰		

4. 위험도 분석 및 대응

위험 시나리오	발생 가능성	영향도	대응 방안	담당부서
DB 직접 접근 후 평문 데이터 유출	낮음	매우 높음	AES-256 암호화 + 접근 로그 실시간 모니터링	정보보호팀
카드번호 원문 저장으로 PCI-DSS 위반	낮음	높음	토큰화 처리 + 원문 미저장 정책 강제	개발팀
암호화 키 탈취	매우 낮음	매우 높음	HSM 기반 키 보관 + 2인 이상 접근 원칙	정보보호팀
취약 알고리즘 잔존	낮음	높음	분기 점검 + 레거시 시스템 마이그레이션 계획	IT팀

5. 문서 승인 이력

버전	작성일	작성자	변경 내용	승인자	승인일
v1.0	2025.11		최초 작성		